

# PROJECT ERNIE

## V4.1 CONVERGED SPEC

AI-Native Finance Firm Operating System  
MVP Slice + Security/Reliability Hardening + P0+ Patches

|             |                        |
|-------------|------------------------|
| Version     | V4.1 — Pre-Pilot Patch |
| Date        | January 2026           |
| Status      | MUST ADD BEFORE PILOT  |
| MVP Target  | 6-Week Launch          |
| Deliverable | Monthly Variance Memo  |

### V4.1 Patch Summary — MUST ADD BEFORE PILOT:

- **RELIABILITY P0+:** Circuit breakers, exactly-once envelope, validation timeouts, approval SLA, COA versioning
- **SECURITY P0+:** Reviewer clean room, cross-model safety parity, retention/tombstone policy, n8n least privilege

# TABLE OF CONTENTS

- 1. Executive Summary
- 2. MVP Specification (6-Week Launch)
- 3. Security P0 — Must-Fix Requirements
- 4. Security P0+ — V4.1 Additions [NEW]
- 5. Reliability P0 — Must-Fix Requirements
- 6. Reliability P0+ — V4.1 Additions [NEW]
- 7. Architecture Diagrams
- 8. Validation Layer Specification
- 9. Versioning & Reproducibility
- 10. Standard Operating Procedures
- 11. Model Strategy
- 12. Multi-Model Review Pack
- 13. Acceptance Criteria
- Appendix A: Failure Matrix
- Appendix B: Data Flow Contracts

# 1. EXECUTIVE SUMMARY

Project Ernie V4.1 adds critical pre-pilot patches to the V4 converged spec. These P0+ items were identified during final review and MUST be implemented before any client pilot.

## V4.1 Patch Categories

| Category        | Items                                                                             | Priority  |
|-----------------|-----------------------------------------------------------------------------------|-----------|
| Reliability P0+ | Circuit breakers, exactly-once, validation timeouts, approval SLA, COA versioning | MUST HAVE |
| Security P0+    | Reviewer clean room, cross-model safety, retention policy, n8n least privilege    | MUST HAVE |

## Key Acceptance Criteria (Updated)

| Criterion         | Requirement                                                | Verification       |
|-------------------|------------------------------------------------------------|--------------------|
| Pre-Analysis Gate | No analysis before validation + injection scan pass        | Audit log check    |
| Data Isolation    | No cross-client state access possible by design            | Penetration test   |
| Approval SoR      | Approvals logged outside Slack; Slack cannot approve alone | Workflow audit     |
| Queue Durability  | Exactly-once envelope with at-least-once queue + dedupe    | Chaos engineering  |
| Circuit Breaker   | Health-based routing through fallback chain                | Failure injection  |
| Token Budget      | Aggregate burn guard pauses at >80% daily budget           | Budget test        |
| Clean Room UI     | PII masked by default unless Elevated:PII role             | Role-based test    |
| Log Hygiene       | Logs never leak PII or tokens; n8n redacts before notify   | Log scrubber audit |

## 2. MVP SPECIFICATION (6-Week Launch)

The MVP focuses on a single, high-value deliverable: the **Monthly Variance Memo**. This constrains scope while proving the core pipeline.

### 2.1 Deliverable Definition

| Attribute  | Specification                                                 |
|------------|---------------------------------------------------------------|
| Name       | Monthly Variance Memo                                         |
| Input      | GL Export (CSV/Excel) + Budget File + Prior Period (optional) |
| Output     | PDF memo with variance analysis, KPI summary, charts          |
| Turnaround | < 4 hours from validated upload                               |
| Review     | Human-in-loop approval required before delivery               |
| Delivery   | Secure portal download + encrypted email                      |

### 2.2 MVP Scope Boundaries

| IN SCOPE (MVP)                            | OUT OF SCOPE (Phase 2+)          |
|-------------------------------------------|----------------------------------|
| Single deliverable: Monthly Variance Memo | Voice intake (Riva)              |
| Single intake: Web portal upload          | PersonaPlex experimental voice   |
| Single model + fallback chain + stub mode | Moltbot client-facing DM pairing |
| Versioned COA templates (semver + hash)   | Multi-agent specialization       |
| Slack notifications (not approval)        | CRM auto-sync                    |
| Web portal approval (SoR) with SLA timers | Auto-scaling triggers            |
| Email + portal delivery                   | Multi-deliverable workflows      |

### 2.3 MVP Timeline

| Week | Milestone                 | Deliverable                                                             |
|------|---------------------------|-------------------------------------------------------------------------|
| 1-2  | Infrastructure + Security | Durable queue, injection scanner, namespace isolation, circuit breakers |
| 3    | Validation Pipeline       | Schema validator, COA mapper (versioned), progressive sampling          |
| 4    | LangGraph Brain           | Variance agent, report generator, checkpoint system                     |
| 5    | Human Review + Approval   | Web portal (clean room UI), Slack notify, approval SoR with SLA         |
| 6    | Delivery + Testing        | Email/portal delivery, E2E tests, pilot onboarding                      |

## 3. SECURITY P0 — Must-Fix Requirements

These security requirements are non-negotiable for any client deployment. All must be implemented and verified before MVP launch.

### 3.1 Injection Defense

**Threat:** Adversarial content in CSV/PDF fields could manipulate LLM behavior.

| Control             | Implementation                                                        | Verification        |
|---------------------|-----------------------------------------------------------------------|---------------------|
| Input Sanitization  | Strip markdown, code blocks, prompt-like strings from all text fields | Fielding test suite |
| Field Length Limits | Max 500 chars for descriptions, 100 for names                         | Schema validation   |
| Character Allowlist | Alphanumeric + limited punctuation only                               | Regex filter        |
| Content Scanner     | Detect "ignore previous", "system:", "assistant:" patterns            | Pattern matching    |
| Quarantine Queue    | Suspicious files flagged for human review before processing           | Audit log           |

### 3.2 Namespace Isolation

| Control                | Implementation                                                 |
|------------------------|----------------------------------------------------------------|
| Server-Generated UUID  | client_id is UUID generated server-side, never from user input |
| Path Validation        | All file paths validated against client namespace prefix       |
| No User-Supplied Paths | File references by hash only, server resolves to path          |
| Tenant Isolation       | Separate Redis keyspace prefix per client                      |
| Query Scoping          | All DB queries include client_id in WHERE clause               |

### 3.3 Approval System of Record (SoR)

| Component    | Role                                             | Can Approve?     |
|--------------|--------------------------------------------------|------------------|
| Web Portal   | Primary approval interface with full report view | YES — SoR        |
| Slack        | Notification channel with deep link to portal    | NO — notify only |
| Email        | Backup notification with portal link             | NO — notify only |
| Approval Log | Immutable audit trail outside Slack              | N/A — audit      |

### 3.4 Replay/Fork Permission Model

| Operation | Permission Required | Audit |
|-----------|---------------------|-------|
|-----------|---------------------|-------|

|                        |                                       |                            |
|------------------------|---------------------------------------|----------------------------|
| View checkpoint        | read:analysis (default for reviewers) | Logged                     |
| Replay from checkpoint | write:analysis + approval:replay      | Logged + reason required   |
| Fork to new thread     | write:analysis + approval:fork        | Logged + new thread_id     |
| Delete checkpoint      | admin:analysis (restricted)           | Logged + 2-person approval |

## 3.5 Logging Hygiene

- Never log: tokens, API keys, passwords, SSNs, full account numbers
- Redact PII: Names → [NAME], Emails → [EMAIL], Phone → [PHONE]
- Hash sensitive IDs: client\_id logged as SHA256 prefix (first 8 chars)
- Separate log streams: security events → dedicated SIEM sink
- Retention policy: 90 days hot, 1 year cold, then purge

## 4. SECURITY P0+ — V4.1 Additions

[NEW IN V4.1] These security hardening items **MUST** be added before pilot.

### 4.1 Reviewer UI Clean Room

Default masking of sensitive data protects against inadvertent exposure during review.

| Data Type             | Default State               | Reveal Requires   | Audit                 |
|-----------------------|-----------------------------|-------------------|-----------------------|
| Employee Names        | Masked: [NAME-001]          | Elevated:PII role | Logged with viewer ID |
| Salaries/Compensation | Masked: \$***,***           | Elevated:PII role | Logged with viewer ID |
| Vendor Names          | Masked: [VENDOR-001]        | Elevated:PII role | Logged with viewer ID |
| Account Numbers       | Masked: ****1234            | Elevated:PII role | Logged with viewer ID |
| Client Identifiers    | Visible (needed for review) | N/A               | Standard access log   |

#### *Clean Room Implementation Rules:*

- All reveals are audited with: viewer\_id, timestamp, data\_type, memo\_id
- Elevated:PII role requires manager approval and expires after 30 days
- Bulk reveal (>10 items) requires additional justification
- Screenshots in review mode include watermark with reviewer ID

### 4.2 Cross-Model Safety Parity

Injection Scanner must be standalone and model-agnostic to ensure consistent protection.

| Component            | Requirement                                           | Verification             |
|----------------------|-------------------------------------------------------|--------------------------|
| Injection Scanner    | Standalone service, always-on, runs BEFORE any model  | E2E test with all models |
| Scanner Independence | No model-specific logic; same rules for all           | Code review              |
| Fallback Model Entry | Must pass minimal safety/eval suite before pool entry | Eval gate in CI/CD       |
| Model Pool Registry  | Approved models listed with safety eval scores        | Registry audit           |

#### *Fallback Model Safety Eval Suite:*

- Injection resistance: 100% of known prompt injection patterns blocked
- PII handling: No PII in outputs unless explicitly requested with role check
- Refusal consistency: Refuses same categories as primary model
- Output format: Matches expected JSON schema for report generation

### 4.3 Retention vs Deletion (Tombstone/Legal-Hold Policy)

Clear policy for data lifecycle, including legal hold and deletion requests.

| State      | Description                        | Access             | Key Management                |
|------------|------------------------------------|--------------------|-------------------------------|
| Active     | Normal operational data            | Standard roles     | Active encryption key         |
| Archived   | Past retention period, not deleted | Admin only         | Archived key vault            |
| Restricted | Under legal review                 | Legal + Admin only | Sealed key, dual custody      |
| Legal-Hold | Litigation hold, cannot delete     | Legal counsel only | Sealed, audit every access    |
| Tombstone  | Deletion requested, pending purge  | No access          | Key scheduled for destruction |

### Deletion Request Workflow:

1. Client submits deletion request via portal
2. Legal review for any holds (24-hour SLA)
3. If no hold: move to Tombstone state
4. Tombstone data purged after 30-day grace period
5. Encryption key destroyed; data unrecoverable
6. Deletion confirmation sent to client with audit receipt

## 4.4 n8n Least Privilege + Redaction

n8n workflows must operate with minimal privileges and never expose sensitive data externally.

| Control            | Requirement                                                             |
|--------------------|-------------------------------------------------------------------------|
| Network Isolation  | n8n runs in private network only; no public ingress                     |
| Credential Scoping | Each workflow has minimal scoped credentials (read-only where possible) |
| Secret Management  | All secrets in vault; never in workflow definitions                     |
| Error Redaction    | Error workflows MUST redact PII/tokens before any external notification |
| Webhook Auth       | All webhooks require HMAC signature validation                          |
| Audit Trail        | All workflow executions logged with input/output hashes (not content)   |

### Error Notification Redaction Rules:

- Replace all emails: user@example.com → [EMAIL]
- Replace all names: John Smith → [NAME]
- Replace tokens: Bearer abc123... → [TOKEN]
- Replace file paths: /data/client\_abc/file.csv → [FILE\_PATH]
- Keep: error codes, timestamps, workflow IDs (non-sensitive)

## 5. RELIABILITY P0 — Must-Fix Requirements

### 5.1 Durable Queue Architecture

| Component         | Technology                                     | Configuration                        |
|-------------------|------------------------------------------------|--------------------------------------|
| Primary Queue     | Redis Streams or SQS                           | XADD with MAXLEN, visibility timeout |
| Idempotency Key   | intake_hash = SHA256(file_content + timestamp) | Set at receiver                      |
| Dead Letter Queue | Separate stream for failed items               | Max 3 retries, then DLQ              |
| Persistence       | Redis AOF or SQS standard                      | fsync every second                   |
| Consumer Groups   | XREADGROUP for parallel processing             | ACK after successful processing      |

### 5.2 Backpressure Controls

| Control                | Threshold                     | Action                         |
|------------------------|-------------------------------|--------------------------------|
| Queue Depth            | > 100 pending items           | Reject new intake with 429     |
| Per-Client Concurrency | Max 3 simultaneous analyses   | Queue additional requests      |
| Memory Pressure        | > 80% heap usage              | Pause intake, process existing |
| API Rate Limit         | 60 requests/minute per client | Token bucket with burst=10     |
| LLM Token Budget       | 100K tokens/hour per client   | Queue overflow to next hour    |

### 5.3 Recovery Procedures

| Scenario              | Detection           | Recovery                               |
|-----------------------|---------------------|----------------------------------------|
| Queue backup          | Lag > 5 minutes     | Scale workers, alert on-call           |
| LLM timeout           | No response in 60s  | Retry with exponential backoff         |
| Validation failure    | Schema/COA mismatch | Return to client with specific errors  |
| Checkpoint corruption | Hash mismatch       | Restore from previous valid checkpoint |
| Total outage          | Health check fails  | Rate-limited ramp-up from DLQ          |

### 5.4 SLA Timers

| Stage               | Target     | Alert Threshold |
|---------------------|------------|-----------------|
| Intake → Validation | < 1 minute | > 2 minutes     |

|                             |              |              |
|-----------------------------|--------------|--------------|
| Validation → Analysis Start | < 5 minutes  | > 10 minutes |
| Analysis Complete           | < 2 hours    | > 3 hours    |
| Review Assignment           | < 30 minutes | > 1 hour     |
| End-to-End                  | < 4 hours    | > 6 hours    |

## 6. RELIABILITY P0+ — V4.1 Additions

[NEW IN V4.1] These reliability hardening items **MUST** be added before pilot.

### 6.1 Circuit Breakers + Fallback Chain

Health-based routing ensures graceful degradation when components fail.

| Priority | Component             | Health Check                   | Failover Trigger                         |
|----------|-----------------------|--------------------------------|------------------------------------------|
| 1        | Primary LLM (GPT-4)   | Latency < 30s, error rate < 1% | 3 consecutive failures OR >5% error rate |
| 2        | Fallback LLM (Claude) | Same as primary                | 3 consecutive failures                   |
| 3        | Stub Memo Mode        | Always available               | N/A (deterministic)                      |
| 4        | Human Queue           | Reviewer availability          | All automated paths exhausted            |

#### Circuit Breaker States:

- **CLOSED:** Normal operation, requests flow through
- **OPEN:** Failures exceeded threshold, all requests routed to fallback immediately
- **HALF-OPEN:** After cooldown (60s), allow 1 test request to check recovery

#### Stub Memo Mode Specification:

When all LLMs fail, generate deterministic 'Data Quality Report' instead of variance memo:

- Output: PDF with data summary, completeness %, no AI-generated analysis
- Title: 'Data Quality Report — Manual Review Required'
- Content: Account counts, period coverage, balance totals, missing field list
- SLA: < 5 minutes (no LLM latency)
- Next step: Routes directly to human queue for full manual analysis

#### 6.1.1 Token Budget Guard

| Budget Level     | Threshold                   | Action                                 |
|------------------|-----------------------------|----------------------------------------|
| Per-Client Daily | \$50 / 500K tokens          | Alert at 80%, pause client at 100%     |
| Aggregate Daily  | \$500 / 5M tokens           | Alert at 80%, pause all intake at 100% |
| Per-Request      | 32K input, 4K output        | Truncate or split request              |
| Hourly Burst     | 100K tokens/hour per client | Queue overflow to next hour            |

### 6.2 Exactly-Once Envelope

At-least-once queue delivery + receiver-side deduplication = exactly-once processing.

#### Idempotency Key Formula:

```
idempotency_key = SHA256(file_content_hash + client_uuid + submitted_at)
```

| Stage            | Responsibility            | Implementation                                            |
|------------------|---------------------------|-----------------------------------------------------------|
| Queue            | At-least-once delivery    | Redis Streams with ACK, SQS with visibility timeout       |
| Receiver         | Dedupe before processing  | Check idempotency_key in Redis SET before thread creation |
| Dedupe Timing    | BEFORE thread_id creation | No orphan threads from duplicate intake                   |
| Dedupe TTL       | 24 hours                  | Keys expire after 24h; resubmission creates new analysis  |
| Collision Action | Return existing result    | Client gets same memo without re-processing               |

### 6.3 Validation Timeouts + Progressive Sampling + Quarantine

Hard timeouts prevent validation from blocking the pipeline; progressive sampling optimizes throughput.

| Validation Step          | Timeout                  | On Timeout Action                   |
|--------------------------|--------------------------|-------------------------------------|
| Schema validation        | 30 seconds               | Quarantine + Data Quality Report    |
| Injection scan           | 30 seconds               | Quarantine + alert security         |
| COA mapping              | 60 seconds               | Quarantine + request manual mapping |
| Full validation pipeline | 120 seconds (hard limit) | Quarantine + auto-generate DQR      |

*Progressive Sampling Strategy:*

- **Phase 1 (Sample):** Validate 10% of rows (random sample, min 100 rows)
- **Sample Pass:** Proceed to full validation
- **Sample Fail:** Immediately quarantine; no full scan (saves resources)
- **Phase 2 (Full):** Only runs if sample passes; validates all rows
- **Full Fail:** Quarantine with detailed error list

*Quarantine Behavior:*

- Quarantined files do NOT block queue (async processing continues)
- Auto-generate Data Quality Report for quarantined items
- Notify client with DQR and resubmission instructions
- Quarantine items reviewed by ops within 4 hours

### 6.4 Approval SLA Timers + Escalation Policy

Portal countdown ensures timely review; escalation prevents bottlenecks.

| Timer              | Duration   | Action                                         |
|--------------------|------------|------------------------------------------------|
| Initial Assignment | 30 minutes | Countdown starts when memo enters review queue |
| First Warning      | 2 hours    | Slack/email reminder to assigned reviewer      |
| Escalation Trigger | 3 hours    | Auto-escalate to backup reviewer               |

|                    |         |                                        |
|--------------------|---------|----------------------------------------|
| Second Escalation  | 4 hours | Escalate to review lead + alert ops    |
| Force-Majeure Path | 6 hours | Optional: deliver with watermark + log |

### **Force-Majeure Watermark Delivery:**

- Only enabled if client opts in during onboarding
- Memo delivered with visible watermark: 'PENDING FINAL REVIEW'
- Every force-majeure delivery logged with full audit trail
- Client acknowledgment required before download
- Final approved version replaces watermarked version within 24 hours

## **6.5 COA Template Versioning**

Chart of Accounts templates are versioned with semver and hash verification.

| Field            | Format           | Example                                      |
|------------------|------------------|----------------------------------------------|
| template_id      | UUID             | coa-template-abc123                          |
| version          | semver           | 2.1.0                                        |
| content_hash     | SHA256           | a1b2c3d4e5f6...                              |
| activated_at     | timestamp        | 2026-01-15T10:00:00Z                         |
| activated_by     | user_id          | finance-lead@company.com                     |
| memo_version_log | template_version | Logged per memo: which template version used |

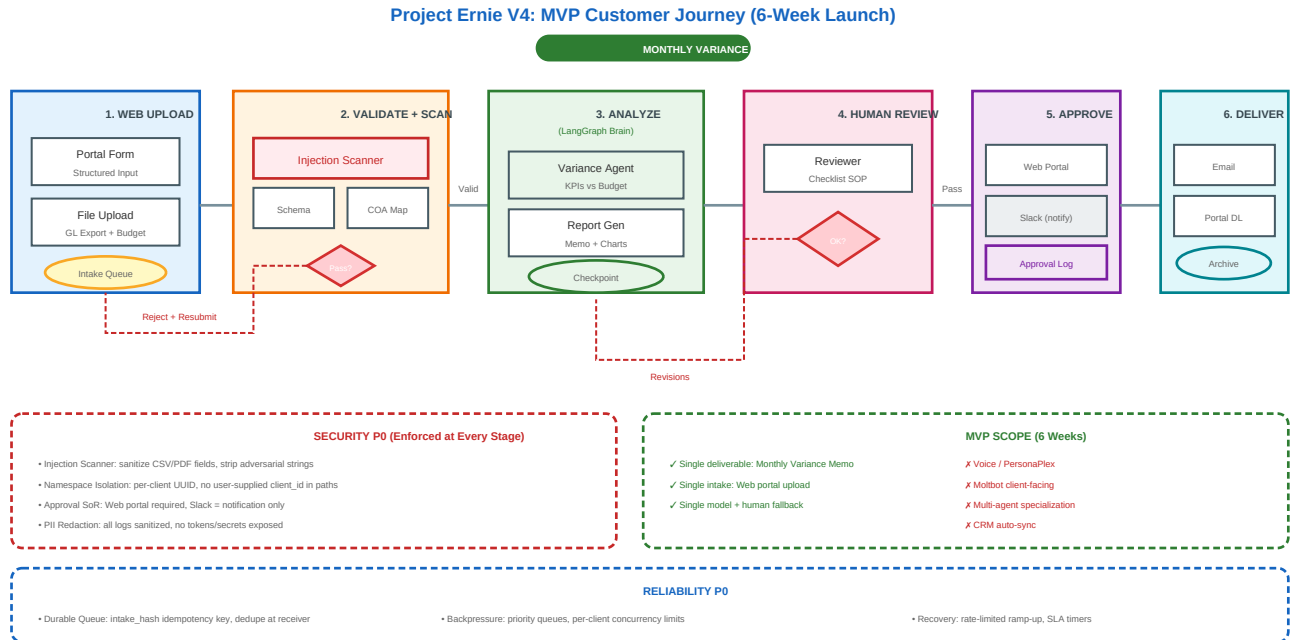
### **Template Change Workflow:**

1. New template version created in staging
2. Hash computed and stored with version metadata
3. Finance lead reviews and approves (required)
4. Template activated; old version archived (not deleted)
5. All memos generated log template\_version for traceability

## 7. ARCHITECTURE DIAGRAMS

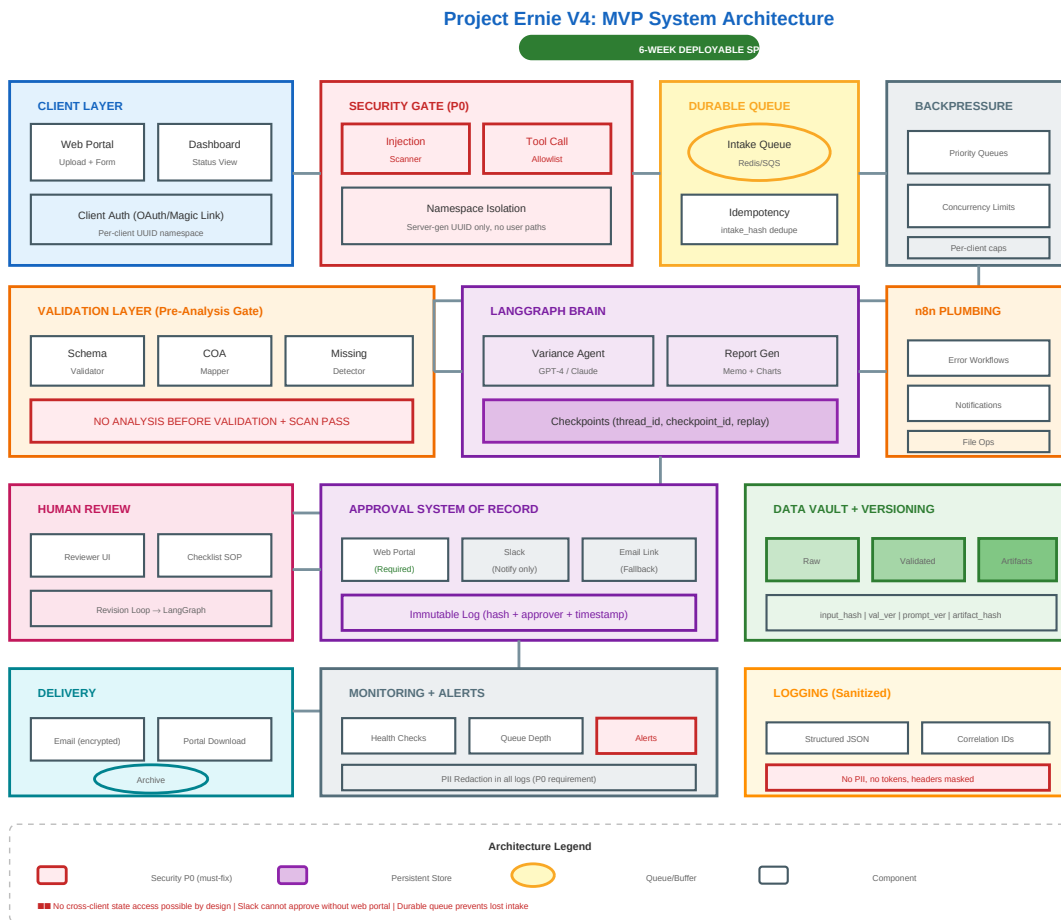
### 7.1 MVP Customer Journey

The MVP journey shows the 6-stage flow from web upload through delivery, with security and reliability controls at each stage.



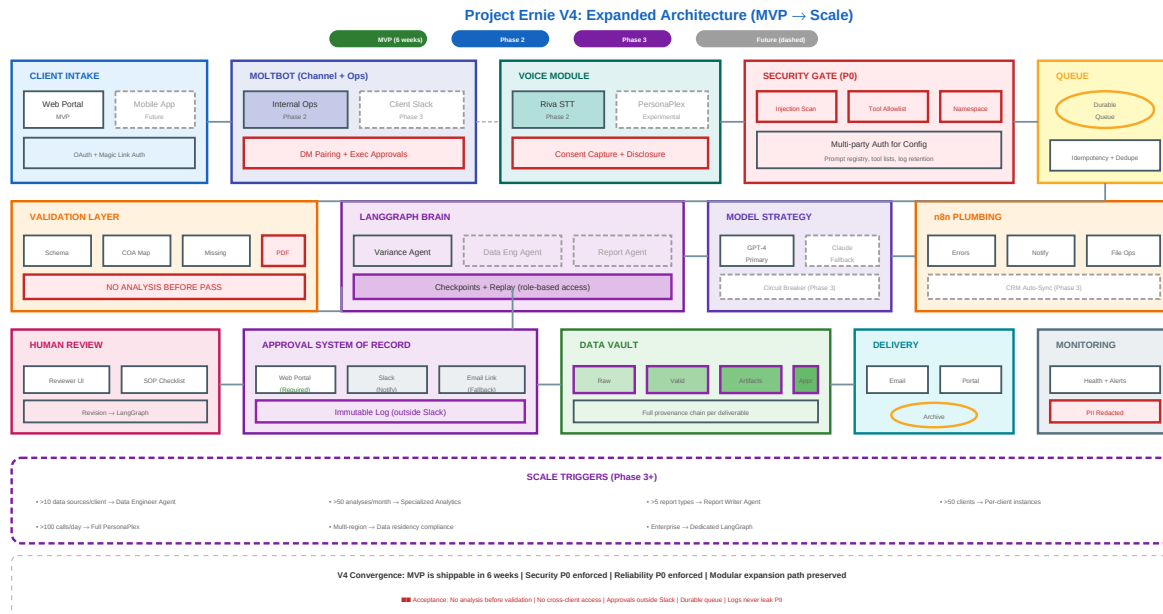
## 7.2 MVP System Architecture

The MVP architecture shows the technical components needed for 6-week launch, with clear separation between security, processing, and delivery layers.



## 7.3 Expanded Architecture (Full Vision)

The expanded architecture shows the complete vision with phased rollout: MVP core → Phase 2 (Moltbot + Voice) → Phase 3 (Scale + Multi-Model) → Future.



## 8. VALIDATION LAYER SPECIFICATION

The validation layer is the critical gate between intake and analysis. No data proceeds to LLM processing without passing all validation checks.

### 8.1 Schema Validator

| Field         | Type    | Required | Validation                                   |
|---------------|---------|----------|----------------------------------------------|
| account_code  | string  | Yes      | Matches COA pattern (e.g., 4xxx for revenue) |
| account_name  | string  | Yes      | Max 100 chars, no special chars              |
| period        | date    | Yes      | ISO 8601 format, within 2 years              |
| actual_amount | decimal | Yes      | Max 15 digits, 2 decimal places              |
| budget_amount | decimal | Yes      | Same as actual_amount                        |
| variance      | decimal | Computed | actual - budget                              |
| variance_pct  | decimal | Computed | (actual - budget) / budget * 100             |

### 8.2 COA Mapper (with V4.1 Versioning)

| Client Code Pattern | Standard Category    | Report Section                   |
|---------------------|----------------------|----------------------------------|
| 4xxx                | Revenue              | Income Statement - Revenue       |
| 5xxx                | COGS                 | Income Statement - Cost of Sales |
| 6xxx                | Operating Expenses   | Income Statement - OpEx          |
| 7xxx                | Other Income/Expense | Income Statement - Other         |
| 1xxx                | Assets               | Balance Sheet - Assets           |
| 2xxx                | Liabilities          | Balance Sheet - Liabilities      |
| 3xxx                | Equity               | Balance Sheet - Equity           |

### 8.3 Missing Data Detector

| Check                | Severity | Action                           |
|----------------------|----------|----------------------------------|
| Required field empty | Error    | Reject file, list missing fields |
| Account not in COA   | Warning  | Flag for review, suggest mapping |
| Period mismatch      | Error    | Reject if periods inconsistent   |
| Duplicate rows       | Warning  | Dedupe and flag                  |

|                      |       |                                                         |
|----------------------|-------|---------------------------------------------------------|
| Balance check failed | Error | Assets $\neq$ Liabilities + Equity $\rightarrow$ reject |
|----------------------|-------|---------------------------------------------------------|

## 9. VERSIONING & REPRODUCIBILITY

### 9.1 LangGraph Checkpoint System

| Field            | Type      | Description                               |
|------------------|-----------|-------------------------------------------|
| thread_id        | UUID      | Unique identifier for client + engagement |
| checkpoint_id    | UUID      | Unique identifier for this state snapshot |
| parent_id        | UUID      | Previous checkpoint (null for initial)    |
| created_at       | timestamp | ISO 8601 with timezone                    |
| state_hash       | SHA256    | Hash of serialized state for integrity    |
| input_hash       | SHA256    | Hash of input files for deduplication     |
| model_version    | string    | LLM model identifier (e.g., gpt-4-0125)   |
| prompt_version   | string    | Git commit hash of prompt templates       |
| template_version | string    | [V4.1] COA template version used          |

### 9.2 Artifact Versioning

| Artifact                 | Storage               | Retention                           |
|--------------------------|-----------------------|-------------------------------------|
| Input files (GL, Budget) | S3 with versioning    | Client contract period + 7 years    |
| Intermediate state       | Redis + S3 backup     | 90 days hot, 1 year cold            |
| Generated reports        | S3 with versioning    | Same as input files                 |
| Prompt templates         | Git repository        | Forever (version control)           |
| COA templates            | S3 + version registry | [V4.1] semver + hash, never deleted |
| Model outputs            | Linked to checkpoint  | Same as intermediate state          |

## 10. STANDARD OPERATING PROCEDURES

### 10.1 Human Reviewer Checklist

| # | Check Item                  | Pass Criteria                              |
|---|-----------------------------|--------------------------------------------|
| 1 | Data completeness           | All required fields populated              |
| 2 | Variance reasonableness     | No unexplained variances > 20%             |
| 3 | Math accuracy               | Totals and percentages verified            |
| 4 | Narrative clarity           | Explanations match data                    |
| 5 | Client context              | Industry norms considered                  |
| 6 | Formatting                  | Professional, consistent styling           |
| 7 | Sensitive data (Clean Room) | [V4.1] No unmasked PII unless Elevated:PII |
| 8 | Delivery ready              | PDF renders correctly                      |

### 10.2 Incident Response SOP

| Severity      | Definition                   | Response Time | Escalation              |
|---------------|------------------------------|---------------|-------------------------|
| P0 - Critical | Data breach, complete outage | < 15 minutes  | CEO + Legal immediately |
| P1 - High     | Client-facing degradation    | < 1 hour      | Engineering lead        |
| P2 - Medium   | Internal system issues       | < 4 hours     | On-call engineer        |
| P3 - Low      | Minor bugs, cosmetic issues  | < 24 hours    | Backlog triage          |

## 11. MODEL STRATEGY

### 11.1 Primary Model Selection (with V4.1 Fallback Chain)

| Use Case            | Primary Model       | Fallback       | Stub Mode            |
|---------------------|---------------------|----------------|----------------------|
| Variance Analysis   | GPT-4 Turbo         | Claude 3 Opus  | Data Quality Report  |
| Report Generation   | GPT-4 Turbo         | Claude 3 Opus  | Data Quality Report  |
| COA Mapping         | GPT-3.5 Turbo       | Claude 3 Haiku | Manual mapping queue |
| Injection Detection | Rule-based (always) | N/A            | N/A                  |

### 11.2 Fallback Logic (Updated V4.1)

1. Primary model timeout (30s) → Retry once with same model
2. Second timeout → Circuit breaker OPEN, route to fallback model
3. Fallback model fails → Route to stub memo mode (Data Quality Report)
4. Stub mode → Routes to human queue for manual analysis
5. Circuit breaker HALF-OPEN after 60s → Test with 1 request
6. Test passes → Circuit breaker CLOSED, resume normal routing

### 11.3 Cost Controls (with V4.1 Budget Guard)

| Control                 | Limit                  | Action on Exceed                       |
|-------------------------|------------------------|----------------------------------------|
| Per-client daily spend  | \$50                   | Alert + pause client intake            |
| Aggregate daily spend   | \$500                  | [V4.1] Alert at 80%, pause all at 100% |
| Per-request token limit | 32K input, 4K output   | Truncate or split                      |
| Monthly budget          | \$2,000 platform total | Alert at 80%, pause at 100%            |

## 12. MULTI-MODEL REVIEW PACK

### 12.1 Grok — Reliability/SRE Review

| Finding                     | Recommendation                             | Status   |
|-----------------------------|--------------------------------------------|----------|
| No durable queue defined    | Add Redis Streams with idempotency         | V4.0     |
| Missing backpressure        | Add queue depth limits, rate limiting      | V4.0     |
| No recovery procedures      | Define ramp-up from outage                 | V4.0     |
| SLA timers undefined        | Add per-stage timing targets               | V4.0     |
| No circuit breakers         | Add health-based routing + fallback chain  | V4.1 NEW |
| Exactly-once not guaranteed | Add idempotency key + dedupe before thread | V4.1 NEW |
| Validation can block queue  | Add timeouts + progressive sampling        | V4.1 NEW |
| Approval bottlenecks        | Add SLA timers + escalation policy         | V4.1 NEW |

### 12.2 Gemini — Security/Compliance Review

| Finding                    | Recommendation                        | Status   |
|----------------------------|---------------------------------------|----------|
| Injection vector via CSV   | Add input sanitization + scanner      | V4.0     |
| Path traversal risk        | Server-generated UUIDs only           | V4.0     |
| Slack as approval SoR      | Move to web portal, Slack notify only | V4.0     |
| Replay permissions unclear | Define explicit permission model      | V4.0     |
| PII visible in review UI   | Add Clean Room with default masking   | V4.1 NEW |
| Fallback model safety gap  | Standalone scanner + eval gate        | V4.1 NEW |
| No deletion policy         | Add tombstone + legal-hold workflow   | V4.1 NEW |
| n8n over-privileged        | Add least privilege + error redaction | V4.1 NEW |

### 12.3 Kimi — Product/MVP Review

| Finding              | Recommendation              | Status |
|----------------------|-----------------------------|--------|
| Scope too broad      | Focus on single deliverable | V4.0   |
| Timeline unrealistic | Define 6-week MVP scope     | V4.0   |
| Voice not ready      | Defer to Phase 2            | V4.0   |

|                           |                                      |          |
|---------------------------|--------------------------------------|----------|
| Multi-model complexity    | Single model + fallback for MVP      | V4.0     |
| COA templates unversioned | Add semver + hash + finance approval | V4.1 NEW |

## 13. ACCEPTANCE CRITERIA (Updated V4.1)

| ID    | Criterion                                           | Test Method                       | Owner      |
|-------|-----------------------------------------------------|-----------------------------------|------------|
| AC-1  | No analysis before validation + injection scan pass | E2E test with malicious payload   | Security   |
| AC-2  | No cross-client state access possible               | Penetration test + code review    | Security   |
| AC-3  | Approvals logged outside Slack with full context    | Workflow audit + log review       | Compliance |
| AC-4  | Exactly-once envelope (dedupe before thread)        | Duplicate submission test         | SRE        |
| AC-5  | Logs never leak PII or tokens; n8n redacts          | Log audit + scrubber verification | Security   |
| AC-6  | MVP deployable in 6 weeks                           | Sprint burndown + demo            | Product    |
| AC-7  | E2E latency < 4 hours                               | Load test with 10 concurrent      | SRE        |
| AC-8  | Human review before every delivery                  | Workflow audit                    | Operations |
| AC-9  | Circuit breaker routes to fallback chain            | Failure injection test            | SRE        |
| AC-10 | Token budget guard pauses at >80%                   | Budget exhaustion test            | SRE        |
| AC-11 | Clean Room masks PII by default                     | Role-based access test            | Security   |
| AC-12 | COA template versioned + logged per memo            | Template audit                    | Compliance |
| AC-13 | Approval SLA escalation works                       | Timeout simulation test           | Operations |

## APPENDIX A: FAILURE MATRIX (Updated V4.1)

| Stage      | Failure Mode           | Detection              | Recovery                          |
|------------|------------------------|------------------------|-----------------------------------|
| Intake     | File upload fails      | HTTP error response    | Retry with exponential backoff    |
| Intake     | Duplicate submission   | idempotency_key match  | [V4.1] Return existing result     |
| Intake     | Oversized file         | Size > 10MB            | Reject with error message         |
| Validation | Schema mismatch        | Validator rejects      | Return specific field errors      |
| Validation | Injection detected     | Scanner flags content  | Quarantine + alert                |
| Validation | Validation timeout     | [V4.1] >120s elapsed   | [V4.1] Quarantine + DQR           |
| Validation | COA unmappable         | No matching pattern    | Human mapping request             |
| Analysis   | Primary LLM timeout    | No response in 30s     | [V4.1] Circuit breaker → fallback |
| Analysis   | Fallback LLM fails     | Same as primary        | [V4.1] Stub memo mode             |
| Analysis   | All models fail        | Circuit breaker OPEN   | [V4.1] Human queue                |
| Analysis   | Token budget exceeded  | [V4.1] >80% daily      | [V4.1] Pause + alert              |
| Analysis   | Checkpoint corrupt     | Hash mismatch          | Restore from parent               |
| Review     | Reviewer unavailable   | Assignment timeout     | [V4.1] Escalate per SLA           |
| Review     | Approval SLA breach    | [V4.1] >3 hours        | [V4.1] Auto-escalate to backup    |
| Review     | Rejection              | Reviewer marks fail    | Return to analysis with notes     |
| Approval   | Portal down            | Health check fails     | Email fallback + on-call          |
| Delivery   | Email bounce           | Delivery failure       | Retry + notify ops                |
| Delivery   | Force-majeure delivery | [V4.1] >6 hours        | [V4.1] Watermark + log            |
| System     | Redis failure          | Connection timeout     | Failover to replica               |
| System     | S3 unavailable         | AWS status             | Queue writes, retry               |
| System     | Complete outage        | All health checks fail | Rate-limited ramp-up from DLQ     |

## APPENDIX B: DATA FLOW CONTRACTS

### B.1 Intake → Validation

| Field                | Type      | Description                                           |
|----------------------|-----------|-------------------------------------------------------|
| intake_id            | UUID      | Unique intake identifier                              |
| client_id            | UUID      | Server-generated client identifier                    |
| idempotency_key      | SHA256    | [V4.1] SHA256(file_hash + client_uuid + submitted_at) |
| files                | array     | List of uploaded files with metadata                  |
| files[].name         | string    | Original filename                                     |
| files[].size         | integer   | File size in bytes                                    |
| files[].content_type | string    | MIME type                                             |
| files[].s3_key       | string    | S3 storage location                                   |
| submitted_at         | timestamp | ISO 8601 submission time                              |

### B.2 Validation → Analysis

| Field            | Type      | Description                             |
|------------------|-----------|-----------------------------------------|
| validation_id    | UUID      | Unique validation identifier            |
| intake_id        | UUID      | Reference to intake                     |
| status           | enum      | passed   failed   warning   quarantined |
| errors           | array     | List of validation errors               |
| warnings         | array     | List of validation warnings             |
| normalized_data  | object    | Validated and mapped data               |
| coa_mappings     | object    | Account code → category mappings        |
| template_version | string    | [V4.1] COA template version used        |
| validated_at     | timestamp | Validation completion time              |

### B.3 Analysis → Review

| Field     | Type | Description                 |
|-----------|------|-----------------------------|
| thread_id | UUID | LangGraph thread identifier |

|                  |           |                                             |
|------------------|-----------|---------------------------------------------|
| checkpoint_id    | UUID      | Current checkpoint                          |
| model_used       | string    | [V4.1] Which model in fallback chain        |
| fallback_reason  | string    | [V4.1] null if primary, else failure reason |
| report           | object    | Generated report content                    |
| report.type      | enum      | [V4.1] variance_memo   data_quality_report  |
| report.summary   | string    | Executive summary text                      |
| report.variances | array     | Variance details by account                 |
| report.pdf_url   | string    | Generated PDF location                      |
| confidence       | float     | Model confidence score 0-1                  |
| completed_at     | timestamp | Analysis completion time                    |

— END OF DOCUMENT —

Project Ernie V4.1 Converged Spec  
MUST ADD BEFORE PILOT  
Confidential — For Internal Use Only  
Generated January 2026